

Cyber Threat Intelligence

Executive Briefing

Report Date: June 30, 2026

Generated: 2026-06-30 13:32 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
0	11	8	1	20

2. Executive Summary

As of June 30, 2026, the security operations center has concluded the analysis of 20 identified vulnerabilities, categorized as 0 Critical, 11 High, 8 Medium, and 1 Low severity findings. The current organizational risk posture is assessed as High, characterized by significant exposure to remote exploitation and unauthorized data manipulation within our development and application environments. The primary concern is CVE-2026-55698, Lockfile Substitution in pnpm, which demands immediate remediation due to its capacity to undermine software supply chain integrity and facilitate malicious code execution. To maintain the confidentiality, integrity, and availability of our systems, the organization must adopt an urgent patch-management cadence and verify current dependency configurations. Immediate response teams are directed to prioritize the containment and mitigation of these high-urgency vulnerabilities to neutralize potential adversarial movement.

3. Critical Action List

- CVE-2026-55698: Immediately restrict pnpm dependency resolution and update all build environments to the patched version within 24 hours.
- CVE-2026-49340: Disable the Gonic createPlaylist function across all production media servers and apply security patches within 48 hours.
- CVE-2026-47424: Implement strict hardening of the OpenAM Groovy script engine and verify access control lists within 48 hours.
- CVE-2026-55700: Sanitize all pnpm manifest inputs and execute comprehensive integrity audits on package dependencies within 72 hours.
- CVE-2026-49338: Audit and enforce granular authorization controls on all Subsonic API endpoints to prevent IDOR exploitation within 72 hours.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
CVE-2026-55698	Lockfile Substitution in pnpm	8.8	High	89/100	CWE-345
CVE-2026-49340	Arbitrary File Write in Gonic cre...	8.1	High	83/100	CWE-22
CVE-2026-47424	RCE via OpenAM Groovy Sandbox Esc...	8.8	High	79/100	CWE-693
CVE-2026-55700	Path Traversal in pnpm Manifest H...	7.1	High	74/100	CWE-22
CVE-2026-49338	IDOR in Subsonic API Playlist Man...	7.1	High	74/100	CWE-285
CVE-2026-49339	Playlist Path Traversal in Gonic	7.1	High	74/100	CWE-22
CVE-2026-48717	OpenAM OAuth Authorization Bypass	8.1	High	73/100	CWE-285
CVE-2026-47426	OAuth Client Impersonation in Ope...	8.1	High	73/100	CWE-287
CVE-2026-55699	Unintended Deletion during pnpm G...	6.5	Medium	69/100	CWE-22
CVE-2026-44840	DQL Injection in Dgraph GraphQL A...	7.5	High	68/100	CWE-943
CVE-2026-55697	Arbitrary Native Engine Installat...	7.5	High	68/100	CWE-78
CVE-2026-55487	Manifest Identity Spoofing in pnpm	7.5	High	68/100	CWE-346
CVE-2026-53523	Host Header Injection in Nezha OA...	6.8	Medium	61/100	CWE-601
CVE-2026-55180	Secret Exposure via pnpm Registry...	6.5	Medium	59/100	CWE-200
CVE-2026-53522	WebSocket Resource Exhaustion in ...	6.5	Medium	59/100	CWE-770
CVE-2026-53465	Heap Overflow in ImageMagick SF3 ...	6.2	Medium	56/100	CWE-122
CVE-2026-54243	CSV Formula Injection in Statamic...	6.1	Medium	55/100	CWE-1236
CVE-2026-54242	SSRF in Statamic via Glide DNS Re...	4.9	Medium	44/100	CWE-367
CVE-2026-53464	Memory Leak in ImageMagick Wand P...	4.0	Medium	36/100	CWE-401
CVE-2026-54244	Insecure Authorization in Statami...	3.5	Low	27/100	CWE-863

5. Detailed Vulnerability Findings

CVE-2026-55698

Finding: Lockfile Substitution in pnpm

CVSS v3.1 Score: 8.8 | Severity: High | Urgency Score: 89/100 | CWE: CWE-345

MITRE ATT&CK: T1195

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	High
Availability Impact	High

Description:

pnpm fails to properly validate the integrity of lockfiles in project environments. An attacker can force the client to resolve and execute arbitrary bytes specified in a malicious lockfile, leading to remote code execution.

Proof of Concept (PoC):

The attacker provides a modified lockfile in a repository. When the developer runs 'pnpm install', the manager ignores standard verification steps and executes the arbitrary bytes specified in the lockfile, compromising the developer machine.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55698>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55698>

CVE-2026-49340**Finding: Arbitrary File Write in Gonic createPlaylist**

CVSS v3.1 Score: 8.1 | Severity: High | Urgency Score: 83/100 | CWE: CWE-22

MITRE ATT&CK: T1190, T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The Gonic createPlaylist function allows authenticated users to write M3U content to arbitrary paths on the server. This can be weaponized to overwrite configuration files or inject executable scripts.

Proof of Concept (PoC):

The attacker sends a crafted playlist creation request containing a path pointing to a system file. The server writes the playlist contents to the target path, potentially leading to remote code execution.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49340>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49340>

CVE-2026-47424**Finding: RCE via OpenAM Groovy Sandbox Escape**

CVSS v3.1 Score: 8.8 | Severity: High | Urgency Score: 79/100 | CWE: CWE-693

MITRE ATT&CK: T1059, T1203

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The Groovy script engine in OpenAM fails to restrict access to sensitive Java classes. An authenticated attacker can escape the sandbox to execute arbitrary code on the underlying server.

Proof of Concept (PoC):

An attacker with low-level administrative access submits a crafted Groovy script that calls restricted Java packages. The

server executes the script in the context of the OpenAM service, leading to full shell access.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-47424>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-47424>

CVE-2026-55700

Finding: Path Traversal in pnpm Manifest Handling

CVSS v3.1 Score: 7.1 | Severity: High | Urgency Score: 74/100 | CWE: CWE-22

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:H/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	None
Availability Impact	Low

Description:

The pnpm package manager is vulnerable to path traversal during manifest installation. A malicious package manifest can force the client to write files outside the intended installation directory, potentially overwriting system files.

Proof of Concept (PoC):

An attacker publishes a package with a crafted manifest name containing directory traversal sequences. When a victim installs this package, pnpm writes arbitrary files to the host filesystem, potentially achieving persistence.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55700>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55700>

CVE-2026-49338

Finding: IDOR in Subsonic API Playlist Management

CVSS v3.1 Score: 7.1 | Severity: High | Urgency Score: 74/100 | CWE: CWE-285

MITRE ATT&CK: T1592

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:L

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	Low

Description:

Subsonic's API lacks adequate authorization checks when accessing playlist data. Any authenticated user can read or delete playlists owned by other users by manipulating the playlist ID.

Proof of Concept (PoC):

An authenticated attacker issues a direct API call to the playlist endpoint with an incremented ID value belonging to another user. The system fails to verify ownership, returning the sensitive data or deleting the target playlist.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49338>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49338>

CVE-2026-49339

Finding: Playlist Path Traversal in Gonic

CVSS v3.1 Score: 7.1 | Severity: High | Urgency Score: 74/100 | CWE: CWE-22

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Gonic is vulnerable to path traversal within the playlist ID parameter. This allows an authenticated user to bypass ownership checks and manipulate arbitrary files on the server.

Proof of Concept (PoC):

The attacker submits a request with a playlist ID formatted as a path traversal string (e.g., ../../etc/passwd). The application fails to sanitize the input, allowing the user to access unintended filesystem locations.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49339>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49339>

CVE-2026-48717

Finding: OpenAM OAuth Authorization Bypass

CVSS v3.1 Score: 8.1 | Severity: High | Urgency Score: 73/100 | CWE: CWE-285

MITRE ATT&CK: T1136, T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

OpenAM suffers from an authorization bypass vulnerability related to PKCE challenge handling. Attackers can leverage this flaw to intercept or spoof legitimate OAuth flows, facilitating account takeover.

Proof of Concept (PoC):

An attacker intercepts the authorization request and modifies the PKCE challenge parameters. The OpenAM server incorrectly validates the altered flow, allowing the attacker to receive valid authorization tokens for a victim user.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48717>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48717>

CVE-2026-47426

Finding: OAuth Client Impersonation in OpenAM

CVSS v3.1 Score: 8.1 | Severity: High | Urgency Score: 73/100 | CWE: CWE-287

MITRE ATT&CK: T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Improper cache management of the JWKS resolver allows an attacker to manipulate token validation logic. This leads to successful client impersonation, undermining the trust model of the OAuth deployment.

Proof of Concept (PoC):

The attacker poisons the JWKS cache by providing a malicious public key reference. Subsequent authentication attempts are validated against the attacker-controlled key, enabling the generation of forged JWT tokens.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-47426>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-47426>

CVE-2026-55699

Finding: Unintended Deletion during pnpm Global Removal

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 69/100 | CWE: CWE-22

MITRE ATT&CK: T1485

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:H/PR:L/UI:N/S:U/C:N/I:L/A:H

Attack Vector	Local
Privileges Required	Low
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	High
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

A vulnerability in pnpm's global removal process allows a specific bin name to trigger the deletion of the PNPM_HOME directory. This can cause localized denial of service and data loss for development environments.

Proof of Concept (PoC):

A local attacker triggers a package removal using a specially crafted package definition. The logic incorrectly identifies the PNPM_HOME directory as a target for cleanup, resulting in the removal of all installed global dependencies.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55699>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55699>

CVE-2026-44840

Finding: DQL Injection in Dgraph GraphQL API

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-943**MITRE ATT&CK: T1190****CVSS v3.1 Scoring Criteria:**

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Dgraph is susceptible to DQL injection via the checkUserPassword GraphQL query. An attacker can manipulate backend database queries to bypass authentication or extract sensitive user metadata.

Proof of Concept (PoC):

An attacker sends a crafted GraphQL query to the checkUserPassword endpoint containing injected DQL syntax. The Dgraph engine executes the altered query, allowing unauthorized access to stored user credentials or data.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-44840>Ref: <https://www.cve.org/CVERecord?id=CVE-2026-44840>**CVE-2026-55697****Finding: Arbitrary Native Engine Installation in pnpm****CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-78****MITRE ATT&CK: T1204****CVSS v3.1 Scoring Criteria:**

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	High
Availability Impact	High

Description:

pnpm's configuration handling allows for the selection of arbitrary native install engines via configDependencies. This enables attackers to force the execution of malicious native binaries.

Proof of Concept (PoC):

An attacker creates a malicious package with a custom configDependency. When a victim installs the package, the pnpm CLI automatically invokes the attacker's defined native engine, resulting in arbitrary command execution.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55697>Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55697>**CVE-2026-55487****Finding: Manifest Identity Spoofing in pnpm****CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-346****MITRE ATT&CK: T1195**

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	High
Availability Impact	High

Description:

pnpm fails to correctly verify package manifest identity, allowing for the satisfaction of 'allowBuilds' policies with malicious code. This permits unauthorized lifecycle script execution.

Proof of Concept (PoC):

The attacker publishes a package that mimics the identity of a trusted dependency. When a project installs the malicious package, pnpm incorrectly trusts the manifest, executing included lifecycle scripts.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55487>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55487>

CVE-2026-53523**Finding: Host Header Injection in Nezha OAuth**

CVSS v3.1 Score: 6.8 | Severity: Medium | Urgency Score: 61/100 | CWE: CWE-601

MITRE ATT&CK: T1566

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Changed
Integrity Impact	Low

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	None

Description:

Nezha Monitoring is vulnerable to Host Header Injection during OAuth2 redirect URL construction. Attackers can redirect victims to malicious sites, facilitating phishing or credential theft.

Proof of Concept (PoC):

An attacker sends a request with a modified Host header to the OAuth endpoint. The application uses the manipulated host to build the callback URL, redirecting the victim's browser to the attacker's phishing portal.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53523>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53523>

CVE-2026-55180**Finding: Secret Exposure via pnpm Registry Requests**

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-200

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	High
Availability Impact	None

Description:

Configuration options in pnpm can be abused to inject victim environment secrets into outgoing registry requests. This results in the leakage of sensitive credentials to an attacker-controlled endpoint.

Proof of Concept (PoC):

The attacker provides a configuration file that causes pnpm to expand environment variables containing tokens or secrets into URL parameters. The victim's pnpm instance then sends these secrets to the attacker's registry.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55180>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55180>

CVE-2026-53522**Finding: WebSocket Resource Exhaustion in Nezha**

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-770

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

Nezha Monitoring fails to limit WebSocket streams, allowing an attacker to open an unbounded number of connections. This leads to resource exhaustion and a denial of service condition.

Proof of Concept (PoC):

An attacker creates a script that initiates a large volume of concurrent WebSocket connections to the Nezha monitoring instance without closing them. The server exhausts its socket limit, preventing legitimate users from connecting.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53522>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53522>

CVE-2026-53465**Finding: Heap Overflow in ImageMagick SF3 Encoder**

CVSS v3.1 Score: 6.2 | Severity: Medium | Urgency Score: 56/100 | CWE: CWE-122

MITRE ATT&CK: T1203

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:H

Attack Vector	Network
Privileges Required	None

Attack Complexity	Low
User Interaction	Required

Scope	Unchanged
Integrity Impact	Low

Confidentiality Impact	Low
Availability Impact	High

Description:

A heap-based buffer overflow exists in ImageMagick's SF3 encoder. Processing a maliciously crafted multi-frame image can trigger a crash or allow arbitrary code execution.

Proof of Concept (PoC):

An attacker uploads a specially crafted SF3 image file. When ImageMagick attempts to parse the multi-frame structure, the heap overflow occurs, allowing the attacker to overwrite memory and potentially control execution flow.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53465>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53465>

CVE-2026-54243**Finding: CSV Formula Injection in Statamic Exports**

CVSS v3.1 Score: 6.1 | Severity: Medium | Urgency Score: 55/100 | CWE: CWE-1236

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Changed
Integrity Impact	Low

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	None

Description:

Statamic exports are vulnerable to CSV formula injection. Untrusted user input submitted via forms is rendered without escaping, leading to potential command execution when opened in spreadsheet software.

Proof of Concept (PoC):

An attacker submits a form entry containing a CSV formula (e.g., =CMD|' /C calc!A0). When a system administrator exports the submissions and opens them in Excel, the malicious formula executes.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-54243>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-54243>

CVE-2026-54242**Finding: SSRF in Statamic via Glide DNS Rebinding**

CVSS v3.1 Score: 4.9 | Severity: Medium | Urgency Score: 44/100 | CWE: CWE-367

MITRE ATT&CK: T1595

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	High
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

Statamic's Glide component is vulnerable to SSRF through DNS rebinding attacks. This allows an attacker to bypass firewalls and interact with internal network resources.

Proof of Concept (PoC):

An attacker configures a domain that resolves to a public IP initially and then rebinds to an internal IP. They supply this domain to the Glide image processor, which fetches the resource, enabling the attacker to scan or access internal services.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-54242>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-54242>

CVE-2026-53464

Finding: Memory Leak in ImageMagick Wand Parser

CVSS v3.1 Score: 4.0 | Severity: Medium | Urgency Score: 36/100 | CWE: CWE-401

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	Low

Description:

ImageMagick suffers from a memory leak when parsing invalid arguments via the Wand interface. Repeated exploitation can lead to resource exhaustion and service instability.

Proof of Concept (PoC):

An attacker sends a series of requests with malformed arguments to the application using the Wand interface. Each request leaks memory, eventually consuming all system memory and causing the service to become unresponsive.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53464>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53464>

CVE-2026-54244

Finding: Insecure Authorization in Statamic CMS

CVSS v3.1 Score: 3.5 | Severity: Low | Urgency Score: 27/100 | CWE: CWE-863

MITRE ATT&CK: T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	None

Description:

Statamic CMS allows view-only users to submit Live Preview content, which is reserved for editors. This unauthorized

access violates the principle of least privilege.

Proof of Concept (PoC):

A user with low-level view access authenticates to the CMS and sends a POST request to the Live Preview endpoint. The CMS fails to verify that the user possesses 'editor' permissions, allowing the submission.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-54244>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-54244>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from the GitHub Advisory Database and cross-references active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. All CVE identifiers, CVSS scores, and CWE mappings are sourced directly from official databases and are verifiable via the references provided in Section 5. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- GitHub Advisory Database -- <https://github.com/advisories>
- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>